

Reference sample — written for the BlueWave Telecom scenario, not your Sankofa Digital case. The structure, length, and writing style are what to copy. The findings are not.

Stage 0 Capstone · Deliverable 3

Business impact and next steps

Prepared for: BlueWave Telecom Incident Committee **Author:** Janet Mukami Kariuki **Intern code:** UBI-2026-DEMO **Date completed:** 02 June 2026 **Programme:** Ubuntu Bridge Initiative · Cybersecurity Internship · Cohort 1 **Stage:** 0 · Induction at the Gate

Headline finding

BlueWave Telecom was compromised in Q4 2023 by an external actor calling themselves "Hyena Collective", who used the stolen SSO credentials of a terminated vendor partner (`vendor-ace.ke`, offboarded 22 October) to access our partner portal between 14 November and 3 December, and who used that access to export customer billing extracts on at least one confirmed occasion (21 November, 03:14 UTC).

Situation summary

The original Tier-1 ticket flagging the activity was closed as routine vendor work. The breach went undetected for nine days, and the dismissal pattern that masked it was not interrupted until a junior analyst on a different shift escalated outside the original analyst's pattern. We have not yet confirmed the full scope of data exfiltrated or whether the OAuth refresh tokens issued to the compromised account were used elsewhere. We are recommending three actions in the next 72 hours, plus one policy change that prevents this gap from re-opening.

What is at risk

The compromised account, `vendor-ace.ke`, had partner-portal scope including read-access to customer billing CSVs for the Western Region service area. One confirmed export request on 21 November (`partner-portal.log:251-263`) pulled at least 240 customer records. Whether the same OAuth refresh tokens were used against other internal APIs is unknown and is the highest open question.

What we know about the attacker

Access originated from a single residential ISP in Nairobi (`102.215.13.4`), with a second IP (`169.150.224.12`) appearing later in the campaign. There were at least four logins across nine days, and the attacker self-identified as "Hyena Collective" — a name decoded from payload 3 of `encoded-blob.txt` and observed as a user-agent fragment in `partner-portal.log:271`. The ISP is small and has been associated with one prior incident at a neighbouring telecom in mid-2023. The pattern of returning to the same compromised account daily is unusual for a financially-motivated actor and is more consistent with intelligence collection or staging for a longer-running operation.

What we cannot yet rule out

We cannot rule out persistence beyond the partner portal — specifically, whether the OAuth refresh tokens issued to `vendor-ace.ke` were used against other BlueWave services (customer-care CRM, billing API, monitoring tools) outside the partner portal. We also cannot rule out lateral movement into customer-care, and we have not yet enumerated the full set of customer records touched by the 21 November export.

One external reference

This incident is principally a Detect-side failure under the NIST Cybersecurity Framework. The attacker technique most directly applicable is MITRE's Valid Accounts — the credentials they used were legitimate, just no longer authorised. Full citations are in the evidence appendix.

Three 72-hour actions

Action 1: Rotate SSO secrets and force-revoke all vendor refresh tokens

Owner: Head of Engineering **Deadline:** within 24 hours **Evidence cited:** `partner-portal.log:251-263`; `vendor-roster.csv:18`

Rotate the SSO signing secret for the partner portal and force-invalidate every outstanding OAuth refresh token issued to vendor accounts in the past 90 days. This terminates any session the attacker still holds, and forces the legitimate active vendors back through fresh authentication on Monday. The operational cost is helpdesk volume from vendor partners re-authenticating; that cost is acceptable. **This action does NOT close the question of what data was exfiltrated during the 14 November – 3 December window** — only Action 2 begins to answer that.

Action 2: Quantify exfiltrated customer data and brief the Communications Authority

Owner: Head of Data Protection **Deadline:** by 18:00 UTC, 72 hours from publication of this memo **Evidence cited:** partner-portal.log:251–263; change-tickets-q4.csv:29 (BWT-29222)

Pull the full export-request log for vendor-ace.ke between 14 November and 3 December, enumerate which customer records were touched, and prepare an incident notification to the Communications Authority of Kenya per the Data Protection Act 2019. Regulator notification carries a 72-hour clock from confirmation of customer-data impact; we are already past discovery but the clock starts at confirmation. The notification should name the count of affected data subjects and the data classes involved. **This action does NOT remediate the systemic process failure that allowed the dismissal to stand for nine days** — that is the systemic recommendation below.

Action 3: Audit all vendor accounts against the offboarding roster

Owner: Head of Vendor Management **Deadline:** within 48 hours **Evidence cited:** vendor-roster.csv (full file); partner-portal.log:142

Cross-reference every active vendor account in the SSO authoritative directory against the termination dates in vendor-roster.csv. Any account whose owning party has been terminated and still has active credentials must be disabled today. There are at least three other vendor entries in the roster with status=terminated that we have not yet verified; those are the priority. This action closes the specific attack vector that succeeded against us. **This action does NOT prevent the same gap from re-opening when new vendors are offboarded in future** — that is also addressed by the systemic recommendation.

Systemic recommendation

Quarterly vendor-access review with mandatory revocation within 72 hours of any termination, signed off by a second analyst before the review can be closed. The review reads vendor-roster.csv against the SSO authoritative directory, surfaces every credential whose owning party is no longer with BlueWave, and forces revocation as a precondition to closure. This recommendation directly addresses the dismissal-pattern documented in D2 around BWT-29104 and BWT-29178: had the roster been the authoritative source rather than a reference Daniel had to remember to check, the pattern could not have hidden the breach. The systemic change is procedural and contractual; it does not require a new tool, and it does not require additional staffing. It does require Engineering to expose the SSO authoritative directory to Vendor Management for the review.

Evidence appendix

- partner-portal.log:142 — SSO acceptance from 102.215.13.4 (BWT-29104 trigger)
- partner-portal.log:218 — repeat from same IP, same account (BWT-29178)
- partner-portal.log:251–263 — OAuth refresh + billing-CSV export request (21 November 03:14–03:23 UTC)
- partner-portal.log:271 — threat-actor self-identification in user-agent string
- partner-portal.log:339 — daytime access during purported Ace change window
- partner-portal.log:381 — pivot to vendor-noor.bw from same source IP
- partner-portal.log:401 — OAuth refresh outside interactive session
- partner-portal.log:412 — second source IP attempt (BWT-29298)
- vendor-roster.csv:18 — vendor-ace.ke terminated 2023-10-22
- vendor-roster.csv:34 — vendor-noor.bw reference row
- change-tickets-q4.csv:24 — BWT-29178 disposition + notes
- change-tickets-q4.csv:29 — BWT-29222 escalation by Lillian Achieng
- change-tickets-q4.csv:38 — BWT-29298 disposition + notes
- encoded-blob.txt payload 3 — decodes to "Hyena Collective"
- NIST Cybersecurity Framework function: Detect (DE)
- MITRE ATT&CK technique: T1078 — Valid Accounts

- Kenya Data Protection Act 2019, Sections 43–45 (notification obligations)
- ISO 27001:2022 Annex A.9.2.6 (Removal of access rights)

Reference sample · BlueWave Telecom scenario · Cohort 1 · Ubuntu Bridge Initiative